

# Acme Corporation Information Security Policy

Security Program — Edition 2024

## 1. Access Control

Access to production systems requires hardware-key MFA and just-in-time elevation. Standing production access is not permitted. All access is reviewed quarterly by system owners.

A new zero-trust network model is being rolled out through 2024. All service-to-service traffic uses mutual TLS. Network segmentation is enforced via Istio service mesh policies.

## 2. Cryptography

Data at rest is encrypted with AES-256. Data in transit uses TLS 1.3. Key management uses AWS KMS with automatic rotation every 90 days. Customer-managed keys are available for enterprise customers.

## 3. Vulnerability Management

Critical vulnerabilities must be remediated within 7 days. High-severity vulnerabilities within 30 days. Medium within 90 days. A new continuous scanning program identifies vulnerabilities in real time rather than through periodic scans.

## 4. Application Security

All applications must undergo threat modeling before release. Static and dynamic analysis run on every PR. Penetration tests are conducted annually by an external firm, and after any significant architectural change.

## 5. Data Protection

Customer data is classified according to the framework defined in the Legal and Compliance Manual. Regulated data requires additional controls including field-level encryption, strict access logging, and quarterly access reviews.

## 6. Third-Party Risk

All third parties with access to Acme systems or customer data must complete a security review. Critical vendors are reviewed quarterly. Continuous monitoring is provided by an external risk intelligence service.

## **7. Security Awareness**

All employees must complete security awareness training within 30 days of hire and annually thereafter. A new phishing simulation program runs monthly. Employees who fail simulations receive targeted training.

## **8. Incident Response**

The Incident Response Team is on call 24/7. Security incidents must be reported within 1 hour of discovery. Confirmed breaches involving personal data must be reported to the relevant supervisory authority within 72 hours.